

SOC 2 Gap Analysis

Distance to SOC 2 Type I & Type II

ORGANIZATION	Alpine Due Diligence Inc.
PREPARED BY	Allen Zhang, Founder & CEO
DATE	April 27, 2026
BASED ON	Compliance Policy Manual v2.0 + Codebase Review
TYPE I TARGET	Q3 2026
TYPE II TARGET	Q1 2027
CLASSIFICATION	Confidential

Overview

This document assesses Alpine Due Diligence Inc.'s current position relative to SOC 2 certification. It compares what is described in the Compliance Policy Manual v2.0 against the actual state of the product codebase and infrastructure, identifying gaps that must be closed before a SOC 2 audit can succeed.

SOC 2 is structured around five Trust Services Criteria (TSC). The two most relevant to Alpine's current stage are Security (CC6-CC9) and Availability (A1). The audit has two stages:

Stage	Definition	Alpine Target
Type I	Point-in-time: are controls suitably designed?	Q3 2026
Type II	6-12 month observation: are controls operating effectively?	Q1 2027

Type I requires that policies exist AND that the technical controls described in those policies are actually implemented. Type II additionally requires continuous evidence that those controls operated without exception over the observation window.

Summary Scorecard

Current control status across the five Trust Services Criteria relevant to Alpine:

Criteria	Area	Policy	Code	Status
CC1-CC3	Control Environment & Risk Assessment	Done	N/A	Ready
CC6	Logical Access Controls	Done	Gap	Blocker
CC7	System Operations & Audit Logging	Done	Gap	Blocker
CC8	Change Management	Done	Partial	Minor Gap
CC9	Risk Mitigation / Vendor Management	Done	Done	Ready
A1	Availability / BCP	Done	Partial	Minor Gap

Blockers must be resolved before a Type I audit can be scheduled. Minor Gaps should be closed during the audit preparation period.

1. What Is Already in Place

The following controls are in place at both the policy documentation level and the technical/infrastructure level. These can be evidenced to an auditor without further work.

Policy Documentation (All Complete)

- Privacy Policy -- published at alpinedd.com/privacy
- Terms of Service -- published at alpinedd.com/terms
- Compliance Policy Manual v2.0 -- 14 appendices covering all key control areas
- Incident Response Plan (Appendix G) -- severity classification, response phases, contacts
- Change Management Policy (Appendix H) -- Git-based workflow matches actual practice
- Data Classification & Handling (Appendix E) -- three-tier classification scheme
- Data Retention & Disposal Schedule (Appendix F) -- with defined periods per data type
- Vendor Management Policy (Appendix J) -- approved vendor inventory with DPA status
- Business Continuity Plan (Appendix K) -- RTO 8 hours, RPO 24 hours, disruption scenarios
- Risk Assessment Register (Appendix M) -- 11 risks with likelihood, impact, and residual rating
- Data Processing Agreement template (Appendix L) -- ready for client execution
- Policy Acknowledgment Form template (Appendix N)

Infrastructure-Level Controls (Provided by Vendors)

- TLS 1.3 encryption in transit -- Cloudflare and Supabase infrastructure layer
- AES-256 encryption at rest -- Supabase database encryption (AWS)
- DDoS protection -- Cloudflare
- Automated daily backups -- Supabase point-in-time recovery
- Anthropic Zero Data Retention (ZDR) -- document text not stored after API response
- Vendor DPAs executed -- Anthropic, Hetzner, Supabase, Resend, Cloudflare
- SOC 2 certified sub-processors -- Anthropic (Type II), Cloudflare (Type II), GitHub (Type II)
- ISO 27001 certified hosting -- Hetzner Online GmbH (EU)

Application-Level Controls (In Code)

- Supabase service_role key used server-side only, never exposed to browser
- Slug guard middleware blocking access to restricted review slugs
- API routes return structured errors and log to server console
- Git version control for all code changes, with documented commit history

2. Critical Gaps -- CC6: Logical Access Controls

CC6 is the largest gap and the primary blocker for SOC 2 Type I. It covers authentication, authorization, session management, and access logging. The compliance policy describes a complete access control framework, but the current codebase implements a demo-only authentication stub that satisfies none of these requirements.

2.1 Authentication -- Demo Stub vs. Policy Requirements

The current login page (app/login/page.tsx) uses a hardcoded credential pair (demo@alpinedd.com / demo123) and stores the session as a plain string in localStorage. There is no call to any authentication backend.

Control	Policy Says	Code Does	Gap
Password storage	bcrypt hashing, never plaintext	Hardcoded string comparison	Critical
Session token	JWT with server-side expiry	localStorage string, no expiry	Critical
Session timeout	Auto-timeout after inactivity	Never expires	Critical
Real user accounts	Per-user accounts with auth	Single shared demo account	Critical

2.2 Multi-Factor Authentication

Policy (Appendix D, Section 5) states: 'Multi-factor authentication (MFA) is required for all administrative access.' MFA has not been implemented at any level.

Supabase Auth includes built-in TOTP MFA -- this can be enabled without a custom implementation.

2.3 Account Lockout

Policy (Appendix C) states: 'Accounts locked after 5 consecutive failed login attempts.' The current login flow returns an error message on failure but performs no lockout, rate limiting, or failed-attempt tracking.

2.4 Role-Based Access Control (RBAC)

Policy (Appendix C, D) describes granular role-based permissions. The current application has no role system. All users of the demo account have identical, unrestricted access to all data. There is no concept of user identity, role assignment, or permission enforcement in any API route.

2.5 Fix: Migrate to Supabase Auth

All CC6 gaps can be resolved by replacing the demo login stub with Supabase Auth, which provides bcrypt password hashing, JWT sessions, MFA (TOTP), and user management out of the box. No third-party auth vendor is required.

Action	Effort	Closes
Replace login/page.tsx with Supabase Auth sign-in	2-3 days	Auth + JWT session
Enable Supabase TOTP MFA for admin accounts	1 day	MFA requirement
Add rate limiting + lockout to login API route	1 day	Account lockout
Implement role column in users table + API middleware	3-5 days	RBAC

3. Critical Gaps -- CC7: System Operations & Audit Logging

CC7 covers the monitoring and logging of system activity. The policy commits to comprehensive audit logging and automated monitoring, neither of which exists in the code.

3.1 Audit Logging

Policy (Appendix C) states: 'Every access event is logged with timestamp, user identity, IP, and action.' Policy (Appendix E) states audit logging is required for all access to Confidential data.

Current state: None of the 14 API routes write to any audit log. There is no `audit_events` table in Supabase. Access to client reports, ratings, notes, and uploaded documents is completely unlogged.

Required Log Event	API Route	Currently Logged
Read report draft	/api/report-draft (GET)	No
Write report draft	/api/report-draft (PUT)	No
Read/write topic rating	/api/topic-rating	No
Read/write notes	/api/notes	No
Read/write flags	/api/flag-draft	No
Upload document	/api/portal/upload	No
Access portal documents	/api/portal/documents	No
All other data API routes	8 additional routes	No

Fix: Create `audit_events` table in Supabase and add a logging helper called from each route.

3.2 Monitoring & Alerting

Policy (Appendix K) references automated monitoring alerts for service disruptions. Policy (Appendix G) describes detection via 'automated monitoring' as Phase 1 of incident response.

Current state: No monitoring system is in place. There is no error tracking, no uptime monitoring, and no alerting. Incidents would only be discovered manually or through client reports.

Monitoring Type	Tool (recommended)	Cost	Priority
Error tracking	Sentry	Free tier available	High
Uptime monitoring	BetterUptime	Free tier available	High
Log aggregation	Logtail / Axiom	Free tier available	Medium

3.3 Backup Restoration Testing

Policy (Appendix K, Risk Assessment) requires quarterly backup restoration testing with documented results. No test has been performed or recorded.

Fix: Perform one restoration test using Supabase point-in-time recovery. Document the result in a simple log.

4. Minor Gaps -- CC8, BCP, and Process Controls

The following gaps do not block a Type I audit but should be closed during the audit preparation period to avoid findings or qualifications.

4.1 Deployment Log (CC8 -- Change Management)

Policy (Appendix H) requires that all deployments are logged with date, time, commit hash, and a summary of changes. Git history satisfies the commit record requirement, but there is no log that explicitly links each production deployment to a timestamp and summary.

Fix: Maintain a simple deployment log (Notion page or spreadsheet) with one row per deploy. Effort: 30 minutes to set up, ongoing discipline to maintain.

4.2 Policy Acknowledgment Records (Appendix N)

Policy requires all personnel to sign the Acknowledgment Form and return it within 5 business days of system access. Annual re-acknowledgment is required on each revision.

Current state: The form template exists in Appendix N but no signed copies have been collected or recorded.

Fix: Founder signs the form for themselves. Collect signed PDFs from all team members and store in a secure folder. For future hires, add this to the onboarding checklist.

4.3 BCP Runbook Completeness (A1 -- Availability)

Policy (Appendix K, Section 3.4) acknowledges founder-unavailability risk and states that 'all recovery procedures are documented in this manual to enable handoff' and that 'infrastructure credentials are stored in an encrypted password manager accessible to a designated backup contact.'

Current state: It is unclear whether a designated backup contact has been named and given access to the password manager. This is a medium-residual risk in the risk register.

Fix: Name a backup contact explicitly. Verify they can access the password manager and run through the server recovery scenario in Appendix K, Section 3.1.

4.4 Penetration Test

The compliance roadmap (Appendix C) lists an external penetration test as In Progress for Q3 2026. A pen test is not strictly required for SOC 2 Type I, but most auditors will ask whether one has been planned or performed.

Recommended vendors for early-stage companies: Cobalt (starts ~\$3,500), Synack, or an independent OSCP-certified tester.

Completing a pen test before the audit strengthens the report significantly.

5. Prioritized Action Plan

Blockers -- Must complete before scheduling Type I audit

#	Action	Effort	Closes
1	Replace demo auth with Supabase Auth (real login)	2-3 days	CC6 Auth
2	Enable Supabase TOTP MFA for admin accounts	1 day	CC6 MFA
3	Add login rate limiting + account lockout (5 attempts)	1 day	CC6 Lockout
4	Implement user roles + RBAC middleware on API routes	3-5 days	CC6 RBAC
5	Create audit_events table in Supabase; add logging to all APIs	3-5 days	CC7 Audit Log
6	Set up Sentry for error tracking	0.5 days	CC7 Monitoring
7	Set up BetterUptime for uptime monitoring	0.5 days	CC7 Availability
8	Select and engage SOC 2 audit firm	2-4 weeks	Audit readiness

Should Do -- Complete during audit preparation period

#	Action	Effort	Closes
9	Start deployment log (Notion / spreadsheet)	0.5 days	CC8 Change Mgmt
10	Collect signed Policy Acknowledgment Forms from all team	1 day	Appendix N
11	Name backup contact; verify password manager access	0.5 days	BCP Key Person
12	Run one Supabase backup restoration test; document result	1 day	CC7 Backup Test
13	Schedule penetration test	1-2 weeks	Security posture

Type II Only -- After audit, during 6-12 month observation period

- Continuously collect audit log evidence (no exceptions in logging)
- Perform quarterly access reviews -- who has access to what, is it still needed
- Annual policy re-acknowledgment workflow for all team members
- Annual vendor review with documented findings
- Complete penetration test and remediate all critical/high findings
- Formalize backup restoration test cadence (quarterly recommended)

6. Timeline

Phase	Activities	Target Date
Phase 1: Technical Controls	Supabase Auth, MFA, lockout, RBAC, audit logging, monitoring	Now - Q2 2026
Phase 2: Process Controls	Deployment log, acknowledgment forms, BCP runbook, pen test bc	Q2 2026
Phase 3: Auditor Engagement	Select firm, complete readiness assessment, address findings	Q2 - Q3 2026
SOC 2 Type I Audit	Point-in-time design assessment	Q3 2026
Type II Observation Begins	6-12 months of evidence collection	Q3 2026
SOC 2 Type II Audit	Operating effectiveness assessment over observation period	Q1 2027

Recommended Audit Firms (Small Company Friendly)

Firm	Notes	Approx. Cost (Type I)
Johanson Group	Popular for early-stage SaaS; fast turnaround	\$12,000 - \$20,000
Prescient	Startup-focused; combined readiness + audit	\$10,000 - \$18,000
Schellman	Mid-market; strong reputation	\$20,000 - \$35,000
A-LIGN	Scalable; good for combined SOC 2 + ISO 27001	\$15,000 - \$25,000

Costs are estimates for SOC 2 Type I only. Type II typically adds 30-50% on top.

7. Most Important First Step

Replace the demo authentication stub with real Supabase Auth.

Every other technical control -- MFA, RBAC, audit logging, session management -- requires knowing who the user is. The current system has no concept of user identity. Until Supabase Auth is integrated, none of the CC6 controls can be evidenced, and audit logging cannot be attributed to a specific user.

Estimated development effort: 1 week.

Impact: closes the single largest blocker for SOC 2 Type I.